



AZ Tecnologia em Gestão Ltda
R 25 de Dezembro, 2071
Campo Grande - MS - 79010-220
F.: (67) 3303-2700 comercial@azi.com.br

POLÍTICA DE GESTÃO DE VULNERABILIDADES

POLÍTICA DE GESTÃO DE VULNERABILIDADES	
Criação	04/02/2026
Última atualização	04/02/2026
Versão vigente	1.0
Motivo atualização	Elaboração
Classificação da Informação	Interna
Responsável Operacional	Gestão de Tecnologia Time de Infraestrutura
Responsável Tático	Data Protection Officer Gestão de Tecnologia
Responsável Estratégico	Alta Direção do Grupo (CEO)
Documentos relacionados	Política de Segurança Cibernética e da Informação

POLÍTICA DE GESTÃO DE VULNERABILIDADES

1. ESCOPO

Estabelecer as regras relacionadas às atividades de identificação, avaliação, documentação, gestão, comunicação, remediação e prevenção de vulnerabilidades.

2. OBJETIVO

O objetivo desta Política de Gestão de Vulnerabilidades (a "Política") é promover a revisão, a avaliação, a aplicação e a verificação das atualizações de ativos de informação que auxiliam a mitigar as vulnerabilidades no ambiente do Grupo AZ, através do tratamento dos riscos associados a tais vulnerabilidades.

3. ABRANGÊNCIA E APLICAÇÃO

Esta política abrange os sistemas e ativos informacionais do Grupo AZ e suas regras são aplicáveis às pessoas que mantém ou mantiveram vínculo com o Grupo AZ, independente da natureza dessa relação, com acesso e/ou necessidade de processamento e uso desses ativos de informação. Quaisquer exceções a esta política deverão ser documentadas em processo de gerenciamento de exceções e aprovadas pela Alta Direção.

As regras aqui estabelecidas poderão ser instrumentalizadas em procedimentos, contratos, manuais e cartilhas, conforme necessário para conscientização e exigência de conduta de cada público.

Esta Política tem aplicação imediata a partir da sua publicação e o seu descumprimento será considerado falta grave, podendo resultar na aplicação de sanções, incluindo a rescisão do contrato.

4. LOCAL E DISPONIBILIDADE

Este documento está disponível para consulta em formato digital para todas as partes interessadas.

5. GLOSSÁRIO

São adotados os seguintes conceitos para os termos-chave e siglas utilizados na Política:

AMEAÇA. Conjunto de fatores externos com o potencial de causarem dano para um sistema ou organização.

ANÁLISE DE VULNERABILIDADES. Verificação e exame técnico de vulnerabilidades, para determinar onde estão localizadas e como foram exploradas.

ANALISTA DE CIBERSEGURANÇA. Responsável pelas ações de segurança da informação.

ATIVOS DE INFORMAÇÃO. Meios de armazenamento, transmissão e processamento da informação, equipamentos necessários a isso, sistemas utilizados para tal, locais onde se encontram esses meios, recursos humanos que a eles têm acesso e conhecimento ou dado que tem valor para um indivíduo ou organização.

BANCO DE DADOS. Coleção de dados inter-relacionados, representando informações sobre um domínio específico. São coleções organizadas de dados que se relacionam, a fim de criar algum sentido (informação) e de dar mais eficiência durante uma consulta ou a geração de informações, ou conhecimento.

CVE (Common Vulnerabilities and Exposures). Vulnerabilidades e Exposições Comuns.

CVSS (Common Vulnerability Scoring System). Sistema comum de pontuação de vulnerabilidade.

HOST. Um computador ou dispositivo de TI (por exemplo, roteador, switch, gateway, firewall).

ID CVE. Identificação para um CVE específico.

GERENCIAMENTO DE VULNERABILIDADE. Processo cíclico e contínuo de identificação, avaliação, documentação, gestão, comunicação e remediação de vulnerabilidades.

GESTÃO DE MUDANÇAS. Processo estruturado que visa aumentar a probabilidade de sucesso em mudanças, com mínimos impactos, e assegurar a disponibilidade, integridade, confidencialidade e autenticidade da informação, nos aspectos relacionados à segurança.

LOG (REGISTRO DE AUDITORIA). Registro de eventos relevantes em um dispositivo ou sistema computacional.

NTP (Network Time Protocol). Protocolo de Tempo para Redes.

PATCH. Uma parte de código adicional desenvolvido para resolver um problema ou falha em um software existente.

PENTEST. Acrônimo de teste de penetração (penetration test).

REMEDIÇÃO. O ato de corrigir uma vulnerabilidade ou eliminar uma ameaça.

RISCO. Possibilidade de ocorrência de um evento que pode impactar o cumprimento dos objetivos do negócio. Pode ser mensurado em termos de impacto e de probabilidade.

RISCO DE SEGURANÇA DA INFORMAÇÃO. Risco potencial associado à exploração de uma ou mais vulnerabilidades de um ou mais ativos de informação, por parte de uma ou mais ameaças, com impacto negativo no negócio da organização.

TESTE DE INVASÃO. Metodologia para testar a eficácia e a resiliência de ativos através da identificação e exploração de fraquezas nos controles de segurança e da simulação das ações e objetivos de um atacante.

TESTE DE PENETRAÇÃO (PENTEST). Também chamado de teste de intrusão, é fundamental para a análise de vulnerabilidades e consiste em testar todos os sistemas em busca de, além das já verificadas na fase anterior, vulnerabilidades conhecidas e disponibilizadas por especialistas ou pelas instituições detentoras dos softwares que estão sendo utilizados pelo órgão ou entidade.

VULNERABILIDADE. Condição que, quando explorada por um criminoso cibernético, pode resultar em uma violação de segurança cibernética dos sistemas computacionais ou redes de computadores, e consiste na interseção de três fatores: suscetibilidade ou falha do sistema, acesso possível à falha e capacidade de explorar essa falha.

6. ESTRUTURA DE GERENCIAMENTO DE VULNERABILIDADES

a. Alta Direção

- Definir diretrizes para a gestão de vulnerabilidades para que todos os níveis da organização compreendam e sigam essas diretrizes.
- Garantir que recursos adequados (financeiros, humanos e tecnológicos) sejam alocados para a identificação, avaliação e mitigação de vulnerabilidades.
- Incentivar uma cultura organizacional que valorize a segurança da informação e a gestão de vulnerabilidades.
- Supervisionar o processo de gestão de vulnerabilidades, monitorando a eficácia das medidas implementadas e ajustando as estratégias conforme necessário.
- Manter uma comunicação clara e transparente com todas as partes interessadas sobre a importância da gestão de vulnerabilidades e os progressos alcançados.
- Garantir que a organização esteja em conformidade com todas as leis e regulamentos aplicáveis relacionados à segurança da informação e proteção de dados pessoais.

b. Data Protection Officer

- Realizar auditorias regulares e análises para identificar possíveis vulnerabilidades de segurança.

- Avaliar os riscos associados a essas vulnerabilidades e determinar a probabilidade e impacto de cada um.
- Implementar controles de segurança adequados para mitigar os riscos identificados, conforme os requisitos da ISO 27001 e outros frameworks de segurança
- Promover treinamentos e capacitações de forma continuada e periódica para todos os funcionários sobre práticas de segurança da informação e privacidade.
- Monitorar continuamente a eficácia dos controles de segurança e revisar e atualizar as políticas e procedimentos conforme necessário.
- Manter uma comunicação clara com a Alta Direção sobre o status da segurança da informação e privacidade, incluindo relatórios regulares sobre incidentes e ações corretivas.
- Garantir que todas as práticas de segurança estejam em conformidade com as leis e regulamentos aplicáveis.

c. Gestores de Área

- Garantir que as políticas de segurança da informação sejam implementadas e seguidas em suas áreas de responsabilidade.
- Promover e assegurar que a equipe esteja ciente das práticas de segurança e privacidade, participando ativamente de treinamentos sempre que necessário.
- Estar atento aos possíveis riscos e vulnerabilidades dentro de suas áreas e reportar qualquer preocupação ao Gestor de Tech / DPO.
- Supervisionar e monitorar continuamente as atividades de suas áreas para garantir a conformidade com as políticas de segurança da informação.
- Coordenar a resposta a quaisquer incidentes de segurança da informação que possam ocorrer dentro de suas áreas, seguindo os protocolos estabelecidos.

d. Todos os Colaboradores, Terceiros e Sócios

- Seguir todas as políticas e procedimentos de segurança da informação estabelecidos pela organização.
- Manter a confidencialidade e integridade dos dados que manuseiam, garantindo que sejam utilizados de maneira segura.
- Informar imediatamente qualquer incidente de segurança da informação ou suspeita de vulnerabilidade.

- Participar dos treinamentos de segurança da informação fornecidos pela organização para se manter atualizado sobre as melhores práticas e novas ameaças.
- Estar atento e vigilante sobre a segurança da informação no dia a dia, evitando comportamentos que comprometam a segurança das informações.

7. REGRAS DE GERENCIAMENTO DE VULNERABILIDADES

O processo de Gerenciamento de Vulnerabilidades (PGV) deve ser criado, implementado, mantido e aplicado. O processo deve conter a implementação de mecanismos para obter informações oportunas sobre vulnerabilidades técnicas dos sistemas e ativos de informação, a avaliação da exposição da organização a tais vulnerabilidades e a implementação de salvaguardas apropriadas para lidar com o risco associado.

a. Mapeamento de Ativos de Informação

O mapeamento de ativos de informação deve determinar qual marca, modelo e versão de equipamento de hardware, sistemas operacionais, banco de dados, sistema, servidor web e aplicativos de software utilizados.

O relatório deve ser atualizado no mínimo anualmente e sempre que ocorrerem alterações significativas para garantir que os recursos informacionais estejam cobertos pelo processo de gerenciamento de vulnerabilidades e patches de segurança.

b. Avaliação de Vulnerabilidades

A avaliação deve ser automatizada e, após a emissão do relatório, analisada por pessoal competente. A avaliação deve considerar também os testes de penetração e outros testes de segurança pertinentes.

i. Detecção de Vulnerabilidades

As principais ações relacionadas à detecção de vulnerabilidades têm como enfoque definir e refinar o escopo que será avaliado; preparar as ferramentas necessárias e verificar sua integridade; e realizar testes e verificar resultados.

A detecção eficaz de vulnerabilidades deve conseguir encontrar vulnerabilidades e reportá-las em tempo hábil para sua correção, de forma a impedir que sejam exploradas.

ii. Realização de Varreduras e Pentests

A enumeração e mapeamento de superfície de ataque devem ser realizados através da modelagem de ameaças junto com varreduras automatizadas e confiáveis. A varredura deve incluir análise de configurações para detectar configurações inadequadas de infraestrutura, bem como dependências para verificar vulnerabilidades em bibliotecas e pacotes de terceiros.

Os testes de segurança devem usar os feeds de vulnerabilidade mais recentes para evitar que certas vulnerabilidades passem despercebidas. Para cada teste, é necessário verificar a integridade da ferramenta utilizada, assegurar que ela escaneou corretamente os ativos analisados e identificar possíveis exceções de vulnerabilidades.

As ferramentas devem ser ajustadas continuamente para evitar que diferentes ferramentas produzam resultados variados.

Frequência de varreduras:

- Varreduras automatizadas: mensalmente, para varreduras básicas de vulnerabilidades com ferramentas como Nessus (exemplo de ferramenta paga), GITHUB e OWASP ZAP (gratuitas).
- Testes de penetração: semestralmente ou após grandes atualizações de software, utilizando especialistas qualificados, preferencialmente terceirizados, como parte de um exercício planejado que inclua o escopo da avaliação, os métodos de uso e os requisitos operacionais. Isso fornece as informações mais precisas e relevantes sobre as vulnerabilidades atuais sem afetar o funcionamento normal.
- Monitoramento contínuo: em tempo real, utilizando ferramentas como GITHUB e Wazuh/OSSEC para detecção de incidentes.
- Auditorias completas: anualmente, englobando todos os aspectos de segurança.

Antes de comunicar os resultados da detecção de vulnerabilidades, é essencial avaliar sua integridade para evitar inconsistências, contradições ou resultados incompletos. A detecção manual de vulnerabilidades pode complementar a detecção automática.

iii. **Análise de Vulnerabilidades**

A pessoa responsável pela Cibersegurança é responsável por emitir e elaborar os relatórios extraídos das ferramentas utilizadas, após cada ciclo de detecção

para auxiliar a entender e mensurar as vulnerabilidades existentes, podendo ser auxiliada pelo time jurídico interno.

Os resultados da varredura devem passar por análise com o dispositivo ou gerenciador de rede para que possíveis falsos positivos possam ser identificados e eliminados.

Grupos de ativos de informação devem ser determinados por tipo de ambiente, por tipo de sistema, por ID CVE ou por tipo de vulnerabilidade.

Devem ser adotadas métricas para os relatórios de vulnerabilidade para determinar o valor percentual dos ativos de informação vulneráveis por gravidade e CVSS.

Todas as versões do relatório devem ser remetidas à DPO e a versão final deve ser aprovada pela Alta Direção.

As métricas são medidas baseadas em uma ou mais referências que servem para mensurar o grau de vulnerabilidade/ameaça em um determinado ativo de informação ou infraestrutura de TI.

Algumas das métricas fundamentais (e não exaustivas) cujo acompanhamento é recomendado em uma estratégia de gerenciamento de vulnerabilidades abrangem: cobertura, tempo de detecção, tempo de permanência, tempo para contenção ou atenuação, número médio de vulnerabilidades ao longo do tempo, eficiência no gerenciamento de patches e resultados de correção em relação aos SLAs da tabela de priorização de vulnerabilidades.

O processo de análise deve estabelecer mecanismos para obter atualizações de software quando emitidas pelo fabricante ou fornecedor oficial regularmente, tais como sites de fornecedores de sistemas, fóruns e grupos de notícias, bancos de dados de gerenciamento de vulnerabilidades e diferentes ferramentas para rastrear as vulnerabilidades mais recentes.

c. Priorização e Correção de Vulnerabilidades

O monitoramento proativo de vulnerabilidades e ameaças em dispositivos, se remediadas, reduzirá ou eliminará o potencial de exploração e economizará os recursos necessários para responder a incidentes após a exploração.

O tratamento de vulnerabilidades deve ser priorizado com base em sua classificação de risco e criticidade, tempo esperado para correção, grau de risco, impacto em caso de exploração e no valor que o ativo ou host impactado tem para os negócios.

As vulnerabilidades devem ser tratadas conforme o seu nível de severidade e nos prazos estipulados pelo gestor de tecnologia.

Quando as vulnerabilidades não puderem ser corrigidas dentro do prazo estabelecido, deve ser enviada uma "solicitação de renúncia" ao Grupo de Trabalho de Privacidade e Proteção de Dados, contendo ao menos as seguintes informações:

- Detalhes do sistema ou ativo.
- Descrição detalhada da vulnerabilidade.
- Se dados pessoais podem ser alvo de exposição.
- Avaliação de risco que justifique a não correção imediata.
- A justificativa clara pela qual a correção não pode ser realizada no prazo estabelecido.
- Detalhes dos controles existentes (se houver).
- Novo prazo de correção.
- Plano de ação da remediação (obedecendo o novo prazo de correção).

A decisão de aceitar ou rejeitar a solicitação de renúncia deve ser tomada com base na avaliação de risco apresentada. Se a solicitação de renúncia for aceita, a vulnerabilidade deve ser monitorada continuamente, pautada pelo plano de ação apresentado e corrigida assim que possível.

8. BANCO DE DADOS DE VULNERABILIDADES

O gerenciamento de vulnerabilidades deve ser apto à produção e manutenção de um banco de dados de vulnerabilidades coletadas de todas as suas fontes. Este banco de dados de vulnerabilidades poderá ser utilizado durante a priorização e a correção de vulnerabilidades.

Além disso, deve ser mantido um banco de dados de vulnerabilidades coletadas de várias fontes, como sites de segurança da informação, boletins de segurança ou publicações de fornecedores de software, que precisam ser aplicadas aos sistemas e ativos informacionais. O banco de dados poderá incluir informações de vulnerabilidade, análise de vulnerabilidade para priorização e plano de correção de vulnerabilidade.

O banco de dados deve ser atualizado regularmente com as informações mais recentes. As novas vulnerabilidades devem ser adicionadas ao banco de dados tão logo forem descobertas.

É recomendável que o banco de dados de vulnerabilidades seja integrado com outras ferramentas de segurança, como scanners de vulnerabilidades e sistemas de gerenciamento de patches. Isso ajuda a identificar e corrigir vulnerabilidades de forma mais rápida e eficiente.

As informações coletadas no banco de dados de vulnerabilidades devem ser analisadas regularmente para identificar tendências e padrões visando a tomada de medidas proativas para evitar futuras vulnerabilidades.

9. APLICAÇÃO DE PATCHES DE SEGURANÇA

Devem ser estabelecidos mecanismos para obter atualizações de software quando emitidas pelo fabricante ou fornecedor oficial regularmente, utilizando recursos autorizados, tais como sites de fornecedores de sistemas, fóruns e grupos de notícias, bancos de dados de gerenciamento de vulnerabilidades e diferentes ferramentas para rastrear as vulnerabilidades mais recentes.

Quando instalações de patches de segurança e ajustes de configuração forem recomendadas para mitigar vulnerabilidades, elas devem ser enviadas por meio da Política de Gestão de Mudanças para os controles apropriados serem implementados para teste, avaliação de riscos e reparação.

a. Monitoramento

Os alertas de vulnerabilidades, as correções de patches e as ameaças emergentes que correspondam aos recursos informacionais relacionados no inventário de sistema e ativos de informação devem ser monitorados.

b. Avaliação de riscos

A avaliação de risco é realizada através da análise de alguns critérios, tais como:

- Impacto na segurança da aplicação ou sistema
- Existência de exploits conhecidos
- Impacto nas operações se a vulnerabilidade for explorada

Para patches críticos, o risco pode ser avaliado imediatamente após a divulgação/descoberta da vulnerabilidade.

c. Testes

Uma vez determinada a necessidade de instalação, deve ser garantido que os patches não causem problemas em produção, através de ferramentas automatizadas e execução de testes de integração em ambiente de homologação, antes de soltar o patch, ou seja, em ambiente isolado e igual ao ambiente de produção.

d. Backup

Para minimizar qualquer impacto de uma falha na aplicação dos patches, é fundamental realizar o backup de sistemas críticos antes da aplicação de qualquer patch e, caso o patch, ainda assim, cause inconsistências, deve ser possível a reversão para o estado anterior.

e. Aplicação do patch em produção

No caso dos patches de baixa ou média prioridade, é possível planejar uma janela de manutenção programada, fora do horário comercial, para minimizar o impacto nos usuários.

Para patches críticos, é fundamental implementar um processo acelerado de aplicação, mas somente após ser realizado de forma bem-sucedida o teste em ambiente de homologação.

A aplicação deve ser feita sempre o mais rápido possível. As vulnerabilidades de zero day com exploits ativos, então podemos avaliar a aplicação dele direto em produção, com monitoramento rigoroso e notificação aos usuários/clientes.

Frequência:

- Patches Críticos: Avaliação imediata e aplicação dentro de 48 a 72 horas, após testes em ambiente separado. No caso dos patches críticos, a aplicação deve ser de 48 horas a 72 horas (incluindo testes, avaliação de riscos, documentação, etc). Caso não seja possível cumprir esse prazo, mudar o cenário para aplicar medidas temporárias de mitigação antes do patch propriamente dito, como bloqueio de portas vulneráveis, até mesmo indisponibilizar o acesso da aplicação por algumas horas.
- Patches de Alta Prioridade: Aplicação em até 2 semanas, sempre após testagem em ambiente de teste.
- Patches de Média/Baixa Prioridade: Podem ser aplicados em janelas de manutenção mensais ou trimestrais, dependendo do impacto.

Podem ser contratadas ferramentas de aplicação de patches de forma automatizada e consistente.

f. Documentação

Toda a atualização deve ser documentada, nos termos da Política de Gestão de Mudanças, incluindo as mudanças realizadas, a data, patch aplicado, sistema afetado, responsável pela aplicação.

g. Monitoramento do Patch

Deve ser realizado o monitoramento do patch aplicado para verificar se não aparecem novos vulnerabilidades e da performance da plataforma nas horas e dias seguintes à aplicação do patch.

10. CONTROLES, MONITORAMENTO E MELHORIA CONTÍNUA

Serão mantidos indicadores de monitoramento para avaliar se a política foi implementada e os controles necessários à garantia da sua proteção foram adotados. Na adoção desses controles, deve ser considerado o amadurecimento da estrutura de proteção das informações na empresa.

Podem ser implementados indicadores para monitorar e melhorar a eficácia da gestão de vulnerabilidades garantindo que a organização esteja em conformidade com as regulamentações e protegendo os dados dos titulares de forma adequada, tais como:

- Tempo de Detecção: Tempo médio necessário para detectar uma vulnerabilidade.
- Tempo de Remediação: Tempo médio necessário para corrigir uma vulnerabilidade após a detecção.
- Número de Vulnerabilidades: Contagem total de vulnerabilidades identificadas.
- Taxa de Remediação: Percentual de vulnerabilidades corrigidas em um determinado período.
- Número de Incidentes de Segurança: Contagem de incidentes de segurança relacionados a vulnerabilidades.
- Satisfação dos Stakeholders: Nível de satisfação dos stakeholders com a gestão de vulnerabilidades.
- Conformidade com Políticas: Grau de conformidade com as políticas de segurança da informação.
- Custo de Remediação: Custo total associado à remediação de vulnerabilidades.
- Frequência de Auditorias: Frequência das auditorias de segurança realizadas.
- Eficácia das Ferramentas: Eficiência das ferramentas de segurança na identificação e remediação de vulnerabilidades.

PROCEDIMENTO DE GESTÃO DE VULNERABILIDADES

Criação	11/02/2026
Última atualização	04/02/2026
Versão vigente	1.0
Motivo atualização	Formalização de procedimento
Classificação da Informação	Restrita
Responsável Operacional	Gestor Tecnologia
Responsável Tático	Time de Infraestrutura
Responsável Estratégico	Alta Direção do Grupo (CEO)
Documentos relacionados	Política de Segurança Cibernética e Segurança de Informação

1. Metodologia

1.1. Abordagem

Utilizaremos uma abordagem de teste de caixa preta, onde os testadores não têm conhecimento prévio da infraestrutura interna. Isso simula um ataque externo realista.

1.2. Ferramentas

- **Openvas:** Para varredura de portas e mapeamento de rede.
- **Nessus:** Para detecção de vulnerabilidades conhecidas.

O Nessus, da Tenable Network Security, e o OpenVAS, da Greenbone Networks, são as ferramentas mais utilizadas no mercado de segurança cibernética.

A decisão de utilizar duas ferramentas foi tomada para evitar o máximo de falso positivo que poderiam ocorrer e também para abranger o máximo de coleções de vulnerabilidades conhecidas.

1.3. Um pouco sobre as ferramentas utilizadas

O Nessus surgiu como um scanner de segurança remoto de código aberto. Vários anos depois, em 2005, a Tenable alterou o modelo comercial do Nessus para uma licença paga, e hoje é uma plataforma de varredura de vulnerabilidades de código fechado, utilizada por mais de 27.000 organizações, que pode detectar 49.572 vulnerabilidades.

Muitas organizações utilizam o Nessus porque ele tem a menor taxa de falsos positivos do mercado, detectando com sucesso ameaças legítimas sem criar notificações desnecessárias (falsos positivos) que, posteriormente, serão tratadas por um usuário humano.

Os principais destaques são:

- Menor taxa de falsos positivos do setor;
- Oferece aos usuários mais de 130.000 plug-ins;
- Lança plug-ins em 24 horas após a descoberta de uma nova vulnerabilidade;
- Menor incidência de falsos positivos do mercado.

Ao contrário do Nessus, o OpenVAS é um scanner de vulnerabilidade de código aberto que começou como um spin-off do próprio Nessus, sendo originalmente denominado GNessus. Somente em 2006 o GNessus se transformou na ferramenta OpenVAS que as empresas reconhecem hoje.

Em 2017, a Greenbone mudou a estrutura OpenVAS para Greenbone Vulnerability Management e transformou o OpenVAS Scanner em um módulo.

Os principais destaques são:

- Código aberto;
- Usa o Greenbone Community Feed para executar mais de 50.000 testes de vulnerabilidade;
- Desenvolvido e mantido gratuitamente pela Greenbone Networks;
- Suporta mais de 44.000 CVEs.

Na realização dos testes de vulnerabilidade utilizamos uma versão trial do Nessus. Ele contém todas as funcionalidades, porém só é válida por 5 dias. Após esse tempo, é necessário realizar outro cadastro no site e validar a chave de acesso.

2. Planejamento

Em conformidade com as diretrizes de *compliance* sobre a frequência de Pentest, a equipe de infraestrutura definiu que a periodicidade será semestralmente.

HIPAA, SOC 2, ISO 27001, LGBA: Não é obrigatório ter uma frequência de teste de intrusão, no entanto, as boas práticas da indústria recomendam que ele seja feito ao menos uma vez por ano.

3.1. Cronograma

- **Semana 1:** Planejamento e configuração do ambiente de teste.
- **Semana 2:** Execução de varreduras de rede e identificação de ativos.
- **Semana 3:** Testes de vulnerabilidade em servidores e dispositivos de rede.
- **Semana 4:** Testes de segurança em aplicações web.
- **Semana 5:** Análise de resultados e elaboração de relatórios.

3.2. Equipe

- **Coordenador de Segurança:** Responsável pela supervisão geral.
- **Analista de Segurança:** Executa testes de vulnerabilidade.
- **Engenheiro de Rede:** Auxilia na configuração e análise de rede.
- **Desenvolvedor de Software:** Foca em testes de aplicações web.

4. Execução

4.1. Identificação de Ativos

Realizar uma varredura completa para identificar todos os dispositivos conectados à rede, incluindo servidores, roteadores, switches e dispositivos IoT.

4.2. Testes de Rede

- Varredura de portas abertas.
- Análise de configuração de firewall.
- Testes de penetração em protocolos de comunicação.

4.3. Testes de Servidores

- Verificação de atualizações de software e patches.
- Testes de configuração de segurança.
- Análise de logs de segurança.

4.4. Testes de Aplicações Web

- Testes de injeção SQL.
- Verificação de vulnerabilidades XSS (Cross-Site Scripting).
- Análise de autenticação e controle de acesso.

5. Relatório

5.1. Sumário Executivo



Resumo dos principais achados e recomendações para a alta administração.

5.2. Detalhamento Técnico

Descrição detalhada de cada vulnerabilidade encontrada, incluindo:

- Descrição do problema.
- Impacto potencial.
- Recomendação de mitigação.

5.3. Plano de Ação

Sugestões para correção das vulnerabilidades identificadas, com prazos e responsáveis.

6. Conclusão

6.1. Avaliação Final

Resumo da eficácia do teste e lições aprendidas para futuros testes de segurança.



(11.02.2026) Política de Gestao de Vulnerabilidades.pdf

Código do documento: ZQGX-ECAE-Q368-G572

**Autenticação Eletrônica**

Valide em <https://app-sign.efcaz.com.br/flowbee-pub/#!/validar/ZQGX-ECAE-Q368-G572>

Ou digite o código: ZQGX-ECAE-Q368-G572

Assinado em conformidade à Medida Provisória nº 2.200-2/2001 e Lei 14.063/2020.

Assinaturas



Eletrônica

elias.mendonca@azi.com.br

e*****ca@azi.com.br

s.mendonca@azi.com

Gestor



Eletrônica

Paulo Cesar Pizzo Sorato

p*****to@azi.com.br

Paulo C. P. Sorato

Representante Legal



Registro eventos

07/05/2026 16:53

elias.mendonca@azi.com.br

Assinou como Gestor. Documento: 887.***.***.**.

Data nascimento: 10/02/1980. Email: e*****ca@azi.com.br. IP: 200.241.189.50. Localização: Cidade: Teresina, Estado: Piauí. Nível de segurança: Validado por código único enviado por e-mail.

RUBRICA

e.

07/05/2026 17:05

Paulo Cesar Pizzo Sorato

Assinou como Representante Legal. Documento: 050.***.***.**.

Data nascimento: 28/04/1963. Email: p*****to@azi.com.br. IP: 200.241.189.50. Localização: Cidade: Teresina, Estado: Piauí. Nível de segurança: Validado por código único enviado por e-mail.

RUBRICA

P.C.P.S.

Hash do documento original: 080f8c90d4d2c6cfd2c12b9a8790138621ec606e3304664c3af415b3624a3107

Hash do documento assinado: 8205b407325d9dd52497833959cdbf414e81f22ef96bbaddc8755fa45323c777
